



Matriz CID

ACTIVO			VALORACIÓN						VULNERABILIDADES	AMENAZAS	EVENTO DE AMENAZA (RIESGO)	CONTROLES
ID_PROCESO	ID_ACTIVO	ACTIVO DE INFORMACIÓN	C	I	D	TOTAL	VALOR 1	VALOR 2				
INC01-26	ACT-01	Consola SIEM	4	4	5	13	Alto	3	Infraestructura sin alta disponibilidad ni balanceo de carga.	Ataque de denegación de servicio (DDoS) distribuido.	Caída del sistema informático y ceguera total en el monitoreo de la red.	Configurar un clúster en espejo (Alta Disponibilidad) y contratar protección perimetral DDoS.
	ACT-02	Registro de logs	3	5	4	12	Alto	3	Almacenamiento de logs en servidores locales con permisos de escritura habilitados.	Actor malicioso que busca borrar sus huellas tras una intrusión.	Modificación o eliminación de registros esenciales para el análisis forense.	Centralizar la recolección de logs en un servidor dedicado con almacenamiento protegido (WORM).
	ACT-03	Base de datos de alertas	3	4	3	10	Medio	2	Ausencia de registros de auditoría interna sobre las modificaciones de la base de datos.	Usuario interno con privilegios elevados que actúa de forma negligente o maliciosa.	Alteración del estatus de alertas críticas para encubrir incidentes reales.	Implementar bitácoras de auditoría de base de datos no modificables y cifrado en reposo.
INC02-26	ACT-04	Consola EDR	4	5	5	14	Alto	3	Configuración laxa en los agentes que permite la desactivación local del servicio.	Infección por malware avanzado diseñado para evadir defensas (antimalware evasion).	Desinstalación del agente EDR en endpoints críticos, permitiendo la libre propagación.	Proteger la configuración del EDR con contraseñas de desinstalación dinámicas desde la nube.
	ACT-05	Evidencia forense digital	4	5	3	12	Alto	3	Falta de cálculo inmediato de firmas hash al momento de recolectar los artefactos.	Manipulación accidental por parte del analista o alteración intencional por un atacante.	Contaminación de la evidencia digital, provocando la invalidez legal de la investigación.	Automatizar el cálculo de hashes (SHA-256) en la recolección y mantener la cadena de custodia.
	ACT-06	Playbook de contención	3	4	4	11	Alto	3	Almacenamiento exclusivo del documento en servidores de archivos de la red corporativa.	Ataque generalizado de Ransomware que cifra los repositorios internos.	Inaccesibilidad a las guías de respuesta rápida durante el pico más crítico de la crisis.	Mantener copias de los playbooks en un repositorio en la nube aislado (fuera de la red) e impresos.
INC03-26	ACT-07	Respaldo de información	4	5	5	14	Alto	3	Copias de seguridad conectadas permanentemente a la red interna sin aislamiento físico.	Propagación lateral de código malicioso de tipo Ransomware.	Cifrado simultáneo de los servidores operativos y de sus respectivos respaldos.	Implementar la estrategia de respaldos 3-2-1 con al menos una copia desconectada
	ACT-08	Reporte final del incidente	4	3	3	10	Medio	2	Guardar el reporte definitivo en carpetas compartidas con permisos de lectura para todo el personal.	Filtración de información confidencial hacia el exterior o actores no autorizados.	Exposición pública de las vulnerabilidades explotadas, facilitando futuros ataques exitosos.	Cifrar el documento final del incidente y restringir su acceso únicamente al Comité de Crisis.



	ACT-09	Bitácora de lecciones aprendidas	3	4	3	10	Medio	2	Registro de hallazgos en texto plano sin asignación explícita de responsables ni fechas límite.	Desinterés operativo o priorización de tareas cotidianas sobre las mejoras de seguridad.	Omisión en el fortalecimiento de controles y reincidencia del mismo incidente de seguridad.	Vincular las acciones de la bitácora directamente al plan de mejora continua y evaluar su cumplimiento mediante KPIs mensuales.
--	--------	----------------------------------	---	---	---	----	-------	---	---	--	---	---

Análisis de vulnerabilidades			
Vulnerabilidades	Severidad	Exposición	Valor3
Infraestructura sin alta disponibilidad ni balanceo de carga	4	4	7
Almacenamiento exclusivo del documento en servidores de archivos de la red corporativa.	4	3	6
Guardar el reporte definitivo en carpetas compartidas con permisos de lectura para todo el personal.	3	5	7

Análisis de amenazas				
Amenazas	Eventos de amenaza	Capacidad	Motivación	Valor4
Ataque de denegación de servicio (DDoS) distribuido.	Caída de servicio	4	4	7
Ataque generalizado de Ransomware que cifra los repositorios internos.	Secuestro de datos	4	5	8
Filtración de información confidencial hacia el exterior o actores no autorizados.	Exfiltración	2	4	5

Riesgo con control = Amenaza x Vulnerabilidad x Probabilidad x Impacto				
Amenaza	Vulnerabilidad	Probabilidad	Impacto	Riesgo Total
7	7	3	13	1274
8	6	2	12	1152
5	7	4	10	1400



Tablas de ponderación

Vulnerabilidades

	Valor	Descripción
Severidad	1	Poca o nula severidad en el grado de vulnerabilidad
	2	Severidad moderada por el grado de vulnerabilidad
	3	Altamente severo el nivel de vulnerabilidad
Exposición	1	Poco o nula exposición
	2	Nivel moderado de exposición
	3	Altamente expuesto

Probabilidad

	Valor	Descripción
Probabilidad de ocurrencia	1	Baja, no hay historial y es raro que la amenazas ocurra.
	2	Media, se han presentado casos y puede ocurrir la amenaza.
	3	Alta, se han presentado suficientes casos y la amenaza seguramente ocurrirá.

Amenaza

	Valor	Descripción
Capacidad	1	Poca o nula capacidad de realizar el ataque.
	2	Capacidad moderada. Se tiene el conocimiento y habilidades para realizar el ataque, pero pocos recursos. O, tiene suficientes recursos, pero conocimiento y habilidades limitadas.
	3	Altamente capaz. Se tienen los conocimientos, habilidades y recursos necesarios para realizar un ataque.
Motivación	1	Poca o nula motivación. No se está inclinado a actuar.
	2	Nivel moderado de motivación. Se actuará si se le pide o provoca.
	3	Altamente motivado. Casi seguro que intentará el ataque.